

# Manual 17 — NIST Privacy Framework Controlled Implementation

Controlled English master

**Series order:** 17

**Stable baseline:** NIST Privacy Framework 1.0

**Source-state decision:** PF 1.1 remains an Initial Public Draft / forthcoming final release as reverified 2026-08-30. Draft 1.1 material is non-normative change-watch intelligence only.

**Publication state:** controlled source; not yet localized, rendered, hash-bound, durably staged, or published.

## Use and boundary

This is an independent implementation guide. It does not reproduce protected third-party text, create certification rights, or convert voluntary NIST guidance into legal requirements. Organizations must separately determine applicable privacy laws, contracts, regulator requirements, sector obligations, and jurisdiction-specific duties.

The implementation model uses the published NIST Privacy Framework 1.0 as the deterministic baseline and organizes governance around the framework's Identify-P, Govern-P, Control-P, Communicate-P, and Protect-P functions while using original implementation language.

## Controlled evidence model

Every implemented privacy control should be traceable through: authority or rationale; accountable owner; repeatable procedure; trigger/frequency; evidence object; evidence location; review/test method; exception/remediation path; and reassessment trigger.

Implementation paths:

- **Essential:** minimum repeatable governance and evidence.
- **Structured:** documented cross-functional operating model with metrics, testing, and escalation.
- **Enhanced:** automated evidence, quantitative analysis, continuous monitoring, and integrated assurance.

## Chapter 1 — Privacy Program Purpose and Operating Model

Define program charter, scope, decision rights, annual operating calendar, escalation thresholds, and management reporting. Owner: executive privacy leader. Evidence: approved charter, RACI, calendar, decision log, governance approvals. Test annually that all required activities have owners, cadence, repositories, and escalation routes. Reassess after major regulatory, organizational, technology, product, or incident change.

## **Chapter 2 — Organizational Context and Interested Parties**

Identify business lines, jurisdictions, individuals, regulators, customers, workforce populations, suppliers, strategic objectives, and dependencies that shape privacy risk. Owner: privacy office with legal and enterprise risk. Evidence: context register, stakeholder inventory, jurisdiction matrix, risk assumptions. Review annually and after market entry, acquisition, restructuring, regulator inquiry, or major contractual change.

## **Chapter 3 — Scope and Boundaries**

Define covered entities, systems, data, products, locations, processes, and third parties; document exclusions and dependencies. Owner: privacy leader with architecture and business owners. Evidence: scope statement, boundary diagrams, exclusion register, dependency map. Reconcile scope against asset, vendor, application, and processing inventories.

## **Chapter 4 — Governance and Leadership Accountability**

Set privacy policy, risk appetite, governance forums, reporting thresholds, resource decisions, escalation, and management review. Owner: executive governance body. Evidence: committee charter, minutes, decisions, risk reports, resource approvals. Test that significant risks and overdue actions reach management with documented disposition.

## **Chapter 5 — Roles, Responsibilities, and Segregation**

Maintain RACI and delegated authorities across privacy, legal, security, engineering, product, data governance, HR, procurement, incident response, audit, and executives. Evidence: job-accountability statements, delegated approvals, segregation rules. Test sampled decisions for authorized approval and independent review where required.

## **Chapter 6 — Processing Inventory and Data Mapping**

Maintain current records of collection, generation, use, sharing, storage, transformation, archival, and deletion of personal data. Record categories, individuals, purposes, sources, recipients, locations, retention, rationale, classification, and processor relationships. Evidence: processing inventory, data flows, owner attestations, reconciliation reports. Reconcile continuously with formal annual review.

## **Chapter 7 — Privacy Risk Assessment Methodology**

Define privacy-risk scenarios, affected individuals, problematic data actions, consequence dimensions, likelihood assumptions, control strength, residual risk, uncertainty, acceptance authority, and reassessment periods. Evidence: approved methodology, assessment

records, assumptions, residual-risk decisions. Reperform samples for scoring consistency and evidence quality.

## **Chapter 8 — Privacy Impact and High-Risk Review**

Screen new or changed processing for enhanced review; document purpose, necessity, data flows, populations, risk scenarios, safeguards, alternatives, residual risk, approvals, and monitoring conditions. Evidence: screening record, impact assessment, approval, conditions, implementation proof. Unapproved high-risk processing is escalated for restriction, redesign, or formal risk decision.

## **Chapter 9 — Policies, Standards, and Procedures**

Maintain a controlled hierarchy linking privacy policy to standards, procedures, owners, approvals, review cycles, and evidence. Evidence: controlled document library, version history, approvals, acknowledgments, retirement archive. Test sampled policy requirements for operational procedures and evidence.

## **Chapter 10 — Privacy by Design and Engineering**

Embed privacy checkpoints into architecture, product, software, data, and change lifecycles. Evaluate minimization, separation, access, retention, transparency, user controls, telemetry, and testability. Evidence: privacy design record, architecture review, risk analysis, decisions, tests, approval conditions. Reassess on material feature, integration, model, or architecture change.

## **Chapter 11 — Purpose Specification and Use Limitation**

Record approved processing purposes and govern material secondary uses. Evidence: purpose register, use-case approvals, change assessments, decision log, notice linkage. Compare actual system and analytics use to approved purposes. Unsupported uses require suspension, narrowing, deletion, or reassessment.

## **Chapter 12 — Data Minimization and Collection Controls**

Require justification for collected attributes, challenge optional fields, eliminate redundant copies, and use aggregation or de-identification when appropriate. Evidence: data-element justifications, schema reviews, collection-form reviews, cleanup records. Test sampled systems for fields lacking current purpose or retention rationale.

## **Chapter 13 — Consent, Preferences, and Individual Choice**

Where consent or preference mechanisms are used, define presentation, capture, proof, withdrawal, propagation, and exception handling. Evidence: consent design, preference records, language versions, propagation logs, withdrawal tests. Perform end-to-end testing that changed preferences reach downstream systems within defined service levels.

## **Chapter 14 — Transparency and Privacy Communications**

Maintain accurate, audience-appropriate privacy notices and internal communications mapped to actual processing. Evidence: notice inventory, processing-to-notice mapping, approvals, version history, publication proof, accessibility/readability review. Correct material inaccuracies promptly and assess affected individuals and obligations.

## **Chapter 15 — Individual Request Operations**

Operate consistent intake, identity verification, routing, search, review, response, exception, and evidence workflows for privacy requests where legally required or voluntarily offered. Evidence: request tickets, verification record, search evidence, response package, exception approval, SLA metrics. Test sampled requests for completeness, authorization, timeliness, and downstream execution.

## **Chapter 16 — Data Quality and Accuracy**

Define where data accuracy materially affects individuals, decisions, services, or obligations; establish correction and propagation processes. Evidence: quality rules, validation logs, correction records, source-of-truth mappings. Review recurring inaccuracies and root causes; reassess when new decision uses or data integrations are introduced.

## **Chapter 17 — Retention, Archival, and Deletion**

Maintain retention schedules tied to documented rationale; implement archival and deletion workflows across production, backup, analytics, and third-party environments where feasible. Evidence: retention schedule, system configuration, deletion logs, exceptions, legal-hold records. Test sampled data stores against approved retention periods.

## **Chapter 18 — Identity, Access, and Privileged Handling**

Apply role-based access, least privilege, authentication, privileged-access controls, periodic access review, and timely revocation to personal data systems. Evidence: access matrices, approvals, logs, recertifications, privileged-session records. Test joiner/mover/leaver and privileged-access samples and remediate excessive access.

## **Chapter 19 — Security and Privacy Coordination**

Integrate privacy requirements with information security risk, vulnerability, logging, monitoring, encryption, incident response, and secure engineering. Evidence: joint control mappings, risk records, security architecture, monitoring outputs, remediation tickets. Verify that security controls address privacy-risk scenarios rather than assuming security alone resolves privacy risk.

## **Chapter 20 — Third-Party and Processor Governance**

Assess vendors and partners before engagement and throughout the relationship. Record processing purpose, data scope, jurisdiction, security/privacy controls, contractual obligations, subprocessors, incidents, retention, return/deletion, and exit terms. Evidence: due diligence, contracts, risk assessments, monitoring, remediation, offboarding proof.

## **Chapter 21 — Cloud and Shared Responsibility**

Document privacy responsibilities across customer, cloud provider, SaaS provider, and subprocessors. Map data locations, administrative access, encryption/key responsibility, logs, retention, deletion, incident notification, and configuration ownership. Evidence: shared-responsibility matrix, architecture diagrams, provider attestations, configuration reviews.

## **Chapter 22 — Cross-Border and Jurisdictional Data Movement**

Maintain visibility of storage, remote access, transfers, onward disclosures, and relevant jurisdictional restrictions. Owner: privacy/legal with architecture and procurement. Evidence: transfer inventory, legal assessment references, contractual mechanisms where applicable, data-location records, approval decisions. Reassess after provider, location, law, or access-model changes.

## **Chapter 23 — Incident and Breach Interface**

Integrate privacy into incident triage, evidence preservation, impact analysis, legal/regulatory assessment, individual-impact assessment, notification decisions, and post-incident remediation. Evidence: incident records, decision logs, timelines, notification assessments, root-cause analysis, corrective actions. Test tabletop scenarios at least annually.

## **Chapter 24 — Monitoring and Control Effectiveness**

Define indicators for control operation, privacy-risk trends, request performance, incidents, complaints, exceptions, third-party findings, stale inventories, and remediation aging. Evidence: dashboards, exception reports, trend analyses, action records. Establish thresholds that trigger escalation and reassessment.

## **Chapter 25 — Privacy Metrics and Management Reporting**

Use metrics that support decisions rather than vanity counts. Define owner, formula, source system, frequency, threshold, target, audience, and action for each metric. Evidence: metric dictionary, dashboards, source reconciliations, management reports. Periodically validate data quality and whether metrics drive decisions.

## **Chapter 26 — Internal Review and Assurance**

Plan risk-based reviews of privacy governance, inventories, assessments, engineering, requests, retention, vendors, incidents, and evidence quality. Preserve reviewer independence proportional to risk. Evidence: review plan, workpapers, samples, findings, management responses, closure validation. Repeat testing after material remediation.

## **Chapter 27 — Corrective Action and Remediation**

Record findings and control failures with severity, root cause, owner, due date, interim safeguards, evidence of correction, and closure validation. Evidence: remediation register, tickets, validation results, risk acceptance if extended. Escalate overdue high-risk items according to governance thresholds.

## **Chapter 28 — Exceptions and Risk Acceptance**

Require documented rationale, scope, risk, compensating measures, owner, approver, expiration, and reassessment for exceptions. Evidence: exception register, approvals, compensating-control tests, expiry alerts. Prohibit indefinite or automatically renewing exceptions without explicit reassessment.

## **Chapter 29 — Training, Awareness, and Role Competence**

Define baseline privacy awareness plus role-specific training for privacy, legal, engineering, product, HR, procurement, security, support, and executives. Evidence: curricula, completion records, assessments, role mappings, remediation for failed training. Review content after major policy, regulatory, technology, or incident changes.

## **Chapter 30 — Evidence Architecture, Maturity Paths, and Implementation Planning**

Maintain a governed evidence repository and traceability model connecting risk decisions, controls, procedures, systems, owners, tests, findings, and remediation. Use Essential, Structured, and Enhanced paths to sequence implementation based on risk and capability. Evidence: control/evidence matrix, implementation roadmap, maturity assessment, dependency map, management approvals.

## **Chapter 31 — Change Triggers and Framework Reassessment**

Define triggers for privacy-program and framework reassessment: legal/regulatory changes, NIST framework updates, incidents, acquisitions, new jurisdictions, new AI/analytics uses, major vendor changes, business-model changes, and repeated control failures. Evidence: change-watch register, source-verification record, impact analysis, controlled change decisions. PF 1.1 final publication requires explicit reconciliation before any release freeze that claims alignment to it.

## **Chapter 32 — Release, Localization, Provenance, and Reassessment**

Freeze the exact controlled-English source only after source/copyright/semantic QA confirms the PF 1.0 scope and non-normative treatment of PF 1.1 draft material. Derive es-419 and pt-BR only from that exact frozen English identity. Require trilingual structural and semantic parity, DOCX/PDF generation, rendered and accessibility QA, SHA-256 binding, provenance manifest, workflow-security checks, durable staging on main, exact-head release QA, predecessor-order verification, and final catalog/release-registry reconciliation before publication.

### **Final controlled-source acceptance checklist**

Before English freeze, verify:

- 32 chapters are present and structurally ordered;
- PF 1.0 is the explicit stable baseline;
- PF 1.1 draft material is not represented as final or binding;
- NIST's voluntary framework character is preserved;
- legal obligations are distinguished from framework guidance;
- every chapter identifies accountable operation, evidence, review/testing, remediation, and reassessment concepts;
- no protected third-party text is reproduced;
- localization has not started from an unfrozen source;
- publication state remains fail-closed until artifact-first gates complete.